

VULNERABILITY SCANNER OVERVIEW:

- **Vulnerability:** It is a weakness or flaw in your software or hardware.

Patching: It is the process of fixing the vulnerability.

~~After a vuln~~ In today's world manually scanning for the vulnerability can be hectic and time consuming, so there are many tools in the market that perform automated scan. After identifying the ~~points~~ vulnerability, changes are made in the software to fix them, these changes are called patches.

- Vulnerability scans are of many types but the major types of vulnerability scans are:

a) **Authenticated Scan:** In this type the scan the credentials of the subject host must be provided to the scanner. The scanner logs into the system and scan for internal vulnerabilities. It finds more vulnerabilities because in this you have full access to system. They can detect misconfigurations, patch issues etc.

b) **Unauthenticated Scan:** In this type of scan the credentials are not provided. It scans from outside like a ~~2~~ attacker. It shows attackers view, what vulnerabilities can attacker scan.

c) **Internal scans:** In these scans are conducted from inside the network. It identifies vulnerabilities that a would be exposed to a attacker once he get access to the network.

d) External scan: In this scan is conducted from outside the network. It identifies the vulnerabilities that can be exposed to the attacker from outside the network.

- There are many tools available for performing automated vulnerability Scanning:

a) Nessus: It is a tool which has extensive vulnerability scanning options, and is widely used by large enterprises.

b) Qualys: It is a tool which provides compliance checks and asset management along with continuous vulnerability scanning. It automatically alerts on the vulnerabilities found during continuous monitoring, moreover it is a cloud-based platform.

c) Nexpose: It is a tool which continuously discovers new assets in the network and performs vulnerability scans on them. It also provides compliance checks against various standards and offers both on-premise and cloud based deployment mode.

d) OpenVAS (Open Vulnerability assessment system): It is a tool which offers basic features with known vulnerabilities scanned through its database. It is used in small organizations or on individual systems.

Almost all these vulnerability scanners offers reporting capabilities. They prepare a detailed report for the vulnerability scanner, their risk scores and detailed descriptions.

- CVE: It stands for common vulnerabilities and Exposures. It was developed by Mitre corporation. Whenever a new vulnerability is discovered it is given a unique CVE number ~~and~~ for reference and is published online in CVE database, so that people can become aware of these vulnerabilities.

Ex: CVE - 2024 - 9374

Every CVE no.

contains this prefix

→ It contains four or more arbitrary digits

year in which vulnerability was discovered

- CVSS : It stands for Common Vulnerability Scoring System. As each vulnerability has a unique identification no., it also has a CVSS score which tells the severity level of the vulnerability. The CVSS score is called by the considering many factors such as its impacts, ease of exploitability etc.

CVSS Score	Severity Level
0-3.9	Low Low
4-6.9	Medium
7-8.9	High
9-10	Critical

- OpenVAS:

Commands for installing OpenVAS via docker arr:

```
sudo apt install docker.io
```

```
sudo docker run -d -p 443:443 --name openVAS mitelplain/openVAS
```

OpenVAS can be accessed through its web interface, where you need to login using the credentials first and then OpenVAS dashboard will open.

• How to perform a vulnerability scan?

click on scans options on the dashboard and then click on tasks you will see all the running tasks here. To create a new task click on the star option and then new task.

a) Now enter the name of the task.

b) In the scan target click the star button and type the name of the target machine and its ip address. Click create.

c) Now we have multiple scan options, each having its scope of scanning. Now select one scan option and click on create.

d) To run the scan click on the play button in the "actions" option of the task.